

Por onde o incidente atravessa o sistema?

Guia detalhado para conduzir modelagem de ameaças e tabletop de ransomware sem malware em 104 minutos.

Carga	Organização	Cenário	Produto
52 + 52 min	grupos de 3–4	TI/OT fictício	modelo + 3 caminhos + risco

Contexto para o professor

A A03 reutiliza o inventário da A02. Uma identidade de suporte aparece em eventos no servidor de arquivos e uma sessão parte da estação de engenharia em direção ao jump host OT. A tensão pedagógica é resistir ao diagnóstico prematuro de ransomware e transformar correlação em perguntas de arquitetura, fronteiras, evidência e consequência.

PERGUNTA MOBILIZADORA

O que precisa ser verdade para que eventos em TI alcancem uma consequência no processo — e onde esse caminho pode ser interrompido com segurança?

Resultados

- Desenhar o funcionamento normal antes do abuso.
- Usar STRIDE para ameaças testáveis e taxonomias com finalidade correta.
- Defender tratamento, validação e risco residual.

1. Preparação

- Validar slides, PDF, links e legibilidade.
- Escolher diagrams.net, Threat Dragon, Mermaid ou papel A3; manter alternativa impressa.
- Preparar três cartões: backup íntegro incerto; conta compartilhada; sessão autorizada rumo ao jump host.
- Explicitar que não haverá malware, criptografia, comando ofensivo ou teste de rede.

Papel	Responsabilidade
Arquiteto	mantém componentes e fluxos legíveis
Adversário autorizado	questiona pré-condições sem executar
Defensor	propõe coleta, controle e validação
Relator	separa evidência, suposição e decisão

PARADA

Destino externo, dado real, tentativa técnica ofensiva, efeito operacional ou discussão que proponha testar sistemas fora do cenário.

Plano B

Se a ferramenta falhar, papel A3 atende integralmente. Se faltar tempo, forneça os componentes e peça que os grupos desenhem apenas fluxos, fronteiras e caminhos.

2. Condução dos slides — 52 min

Tempo/slide	Mediação	Evidência
0–6 • 1	apresentar tensão TI/OT sem diagnóstico	duas observações
6–13 • 2	previsão: caminho, alternativa e dado decisivo	hipóteses concorrentes
13–23 • 3	desenhar fluxo normal; marcar confiança	primeira fronteira
23–35 • 4	STRIDE em um fluxo e um armazenamento	ameaça testável
35–43 • 5	comparar recursos e evitar equivalências	escolha de taxonomia
43–48 • 6	votar no ponto de interrupção	premissa + validação
48–50 • 7	explicar tabletop não destrutivo	critério de parada
50–52 • 8–9	entrega e transição	papéis assumidos

Falas sugeridas

- “O log mostra um caminho completo ou apenas pontos que ainda precisam ser ligados?”
- “Onde muda quem administra, quem autoriza ou qual consequência é possível?”
- “Essa referência descreve fraqueza, padrão ou comportamento?”
- “Que operação legítima o controle pode interromper?”

Não antecipar

- Não confirmar ransomware, comprometimento ou acesso OT.
- Não transformar STRIDE em seis ameaças obrigatórias por elemento.
- Não fornecer um diagrama final antes da primeira versão dos grupos.

3. Mediação da prática — 52 min

Tempo	Ação	Pergunta do professor
52–62	desenho e fronteiras	o que atravessa e por que é confiável?
62–77	ameaças e caminhos	qual condição precisa ser verdadeira?
77–91	cartões do tabletop	que evidência muda a decisão?
91–100	risco e tratamento	qual consequência e risco residual?
100–104	revisão/limpeza	outra equipe consegue validar?

Cartões e facilitação

Cartão	Informação revelada	Boa decisão
A	último teste de restauração é desconhecido	verificar restauração antes de depender do backup
B	svc_support é compartilhada por fornecedor	conter com coordenação; migrar para identidade individual/MFA
C	sessão ao jump host estava no calendário, mas origem diverge	preservar logs, verificar identidade e restringir sem perder acesso seguro

EVIDÊNCIA

A captura do diagrama não basta: cada caminho precisa declarar observações, suposições, consequência e ponto de interrupção.

Pistas

- Comece pelo processo normal, não pelo atacante.
- Circule onde muda identidade, autoridade ou consequência.
- Complete agente + condição + elemento + consequência + evidência.

4. Respostas esperadas e avaliação

Erro produtivo	Intervenção
fronteira = firewall	perguntar onde mudam autoridade, dono e consequência
ATT&CK = vulnerabilidade	retomar comportamento observado versus condição explorável
CAPEC = grupo adversário	retomar padrão, pré-condições e mitigação
risco = número de etapas	pedir consequência, exposição e controles existentes
segmentar resolve tudo	pedir fluxo legítimo, acesso emergencial e validação operacional

Rubrica oral

- Modelo: fluxos nomeados, direção e duas fronteiras.
- Ameaça: agente, condição, elemento, consequência e evidência.
- Taxonomia: finalidade correta, fonte e ausência de mapeamento forçado.
- Risco: consequência, tratamento, responsável, teste e residual.

Fechamento

Peça: “Interrompemos o caminho em ____ com ____; a evidência de eficácia será ____ e o risco residual é ____.” Selecione uma confusão para retomar na A04.

Transferência

Discuta o paradoxo: remover a conexão TI/OT reduz caminhos, mas pode criar manutenção manual, mídia removível ou acesso emergencial menos governado.

Referências

- NIST CSF 2.0; MITRE CAPEC; MITRE ATT&CK Enterprise/ICS; OWASP Threat Modeling.